

Policy Deliverable II: User Access & Authentication Policy

Document ID: BEF-POL-SEC-2026-V1.2

Framework Benchmark: NIST Cybersecurity Framework (CSF) 2.0

Effective Date: July 2, 2026

Classification: Internal Use Only

1. Document Overview

1.1 Purpose

The purpose of this policy is to establish enterprise-wide controls over corporate identity boundaries, enforce granular access architectures, and dictate strict credential lifecycle parameters to maintain secure access management.

1.2 Scope

This policy applies globally to all physical endpoints, local servers, cloud-hosted SaaS infrastructures (e.g., LogiCloud), and logical database accounts owned or operated by BlackSea E-Com Fulfillment (BEF).

2. Authorization and Identity Architecture (PR . AA - 01, PR . AA - 06)

2.1 The Principle of Least Privilege

All logical system permissions, technical parameters, and data rights must strictly adhere to the *Principle of Least Privilege*. Personnel will be provisioned access exclusively to the bare minimum digital assets required to execute their specific organizational job roles. Continuous local administrative privileges on endpoint computing devices are strictly prohibited for general personnel.

2.2 Individual Accountability & Non-Repudiation

The utilization of shared, generic group accounts or master login credentials across multiple hardware devices (such as warehouse floor barcode scanners) is strictly forbidden. Every employee must be assigned a unique, distinct corporate identity credential to guarantee full tracking and accountability.

2.3 Boundary Access Enforcement (PR . AA - 02)

- **Multi-Factor Authentication (MFA):** Multi-Factor Authentication is a mandatory global baseline. Accessing any BEF internal application, email system, or third-party logistical portal requires successful secondary validation alongside standard password submission.
- **Remote Work Infrastructure:** Any employee connecting remotely to corporate infrastructures must pass authentication protocols via a pre-configured enterprise VPN client before accessing internal environments.

3. Credential Lifecycle & Complexity Standards (PR . AA - 05)

All user-managed passwords used across enterprise systems must satisfy the following cryptographic configurations:

- **Length & Complexity Matrix:** Passwords must maintain a minimum length of 14 characters, incorporating an array of uppercase letters, lowercase letters, numerical values, and special symbols.
- **Secure Storage Mandate:** Standard users are strictly prohibited from writing down, hardcoding, or plaintext-saving passwords. All corporate credentials must be generated and stored securely within an enterprise-managed digital Password Manager.
- **Enforced Rotation Cycle:** Passwords must be changed in their entirety every **two (2) months**.

4. Governance, Compliance, & Verification Auditing (GV . OV - 02)

To ensure that identity boundaries do not degrade over time, systemic compliance audits must be executed on a recurring cycle:

1. **System Administrator Validation:** The System Administration team will run automated directory queries monthly to identify and flag any non-compliant accounts, stale credentials, or unrotated profiles.
2. **Independent Compliance Auditing:** An independent internal auditor or designated compliance officer will conduct formal quarterly reviews. This audit verifies password age metrics, ensures least-privilege configurations, and inspects the global state of active MFA requirements across all enterprise systems.